

API Security

1. Financial-grade API (FAPI) Security Profile

This version of the KSA Open Banking Standard is based on **FAPI 2.0 Security Profile**, specifically:

- The OpenID Foundation's [FAPI 2.0 Security Profile](#).
- This security profile is a profile of the FAPI 2 Security Profile with the objective of ensuring backward compatibility with the previous version of the Security Profile and to ensure minimal fragmentation in the ecosystem.
- The Authorization Server **shall** support the provisions specified in **clause 5.3.2** of the [FAPI 2.0 Security Profile](#).

Additional Authorization Server Requirements:

- **Shall only issue sender-constrained access tokens using mTLS** as described in RFC8705.
- **Shall ensure that the access token expiry is no longer than 10 minutes.**
- **Shall authenticate the confidential client using** `private_key_jwt` **or** `tls_client_auth`.
- **Shall use the query parameter as the mechanism for returning authorization response parameters** as the response mode, which is the default for the code response type.
- **Shall advertise support for all signing, authentication mechanisms, and standards required to support this Specification** on its OpenID Connect Discovery (.well-known) endpoint.
- **Shall support and require signed request objects** according to OAuth JWT-Secured Authorization Request (JAR) [RFC9101] at the PAR endpoint [RFC9126].
- **Shall require the aud claim** in the client assertion JWT to be a string equal to the OP's Issuer Identifier URL.
- **Shall require the request object to contain an exp claim** that has a lifetime of no longer than 10 minutes after the nbf claim and an nbf claim that is not more than 10 minutes in the past.
- **Shall only rely on the parameters included in the signed request object passed via the request_uri parameter**, except for the `client_id` parameter.
- **Shall set the response header x-fapi-interaction-id** to the value received from the corresponding client request header, or to an RFC4122 UUID if the request header was not provided, to track the interaction.
- **Shall issue refresh tokens to be the same length as the underlying consent.**

Regarding Tokens:

- **A refresh token must not be rotated** when exchanging for an access token.
- **If consents are limited to 12 months, tokens must not go beyond 12 months.**
- **If a refresh token expires, the consent must be reauthorized.**

Further notes regarding FAPI 2.0

- The OpenID Foundation have provided a [useful guide](#) on the key differences between FAPI 1.0 and FAPI 2.0
- **The KSA FAPI 2.0 Profile and Certification Suite will be published in due course, and you should prepare to align with the final version once released.** SAMA will communicate detailed implementation timelines accordingly.
- Once **KSA FAPI 2 Profile** is finalized, it will become the mandated security profile for this KSA Open Banking Standards.

2. SAMA Security Frameworks

Please refer to the [SAMA Cyber Security Framework](#).